SONY
PICTURES

2007-2009

2011 - 2013

2014

2015 - 2016

2017

2020

2021

2022 -

Recent Performance

2013 Disappointments

Kazuo Hirai, President & CEO Sony Corp.

Philip Reitinger, Global Chief Security Information Officer

Michael Lynton, CEO and Co-Chair Sony Pictures

Amy Pascal, Co-Chair Sony Pictures

Jason Spaltro
CISO Sony Pictures

- Focus investments on security “that are absolutely required by law”
- Would “… not invest $10 million to avoid a possible $1 million loss”

James Franco and Seth Rogan

Kim Jong Un, Supreme Leader North Korea

US Government

Other Key Players

- Sony Pictures employees
- Everyone associated with upcoming movies
- Guardians of Peace

SECURITY AT SONY

Sony’s Security History

- 2005 – Sony BMG Rootkit
- 2008 – PlayStation Site Compromised
- 2011 – PlayStation Network Breach (77M users, > 3-week outage)
- 2011 – Sony Online Entertainment Breach (25M customers)
- 2011 Sony Pictures Website (1M users)

Security Practices

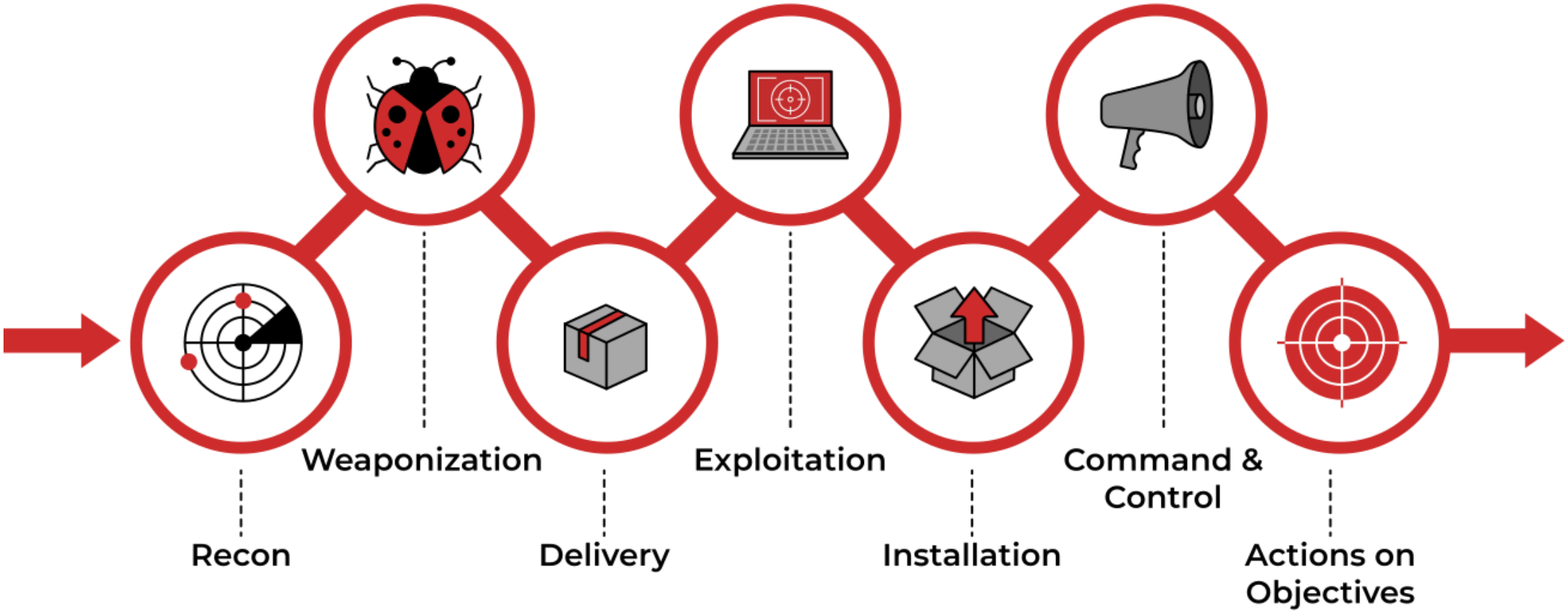
- Passwords?
- 2FA/MFA?
- Encryption?
- Training?
- Data Segmentation?
- Network Segmentation?
- Antivirus?

THE INTERVIEW

[redacted]

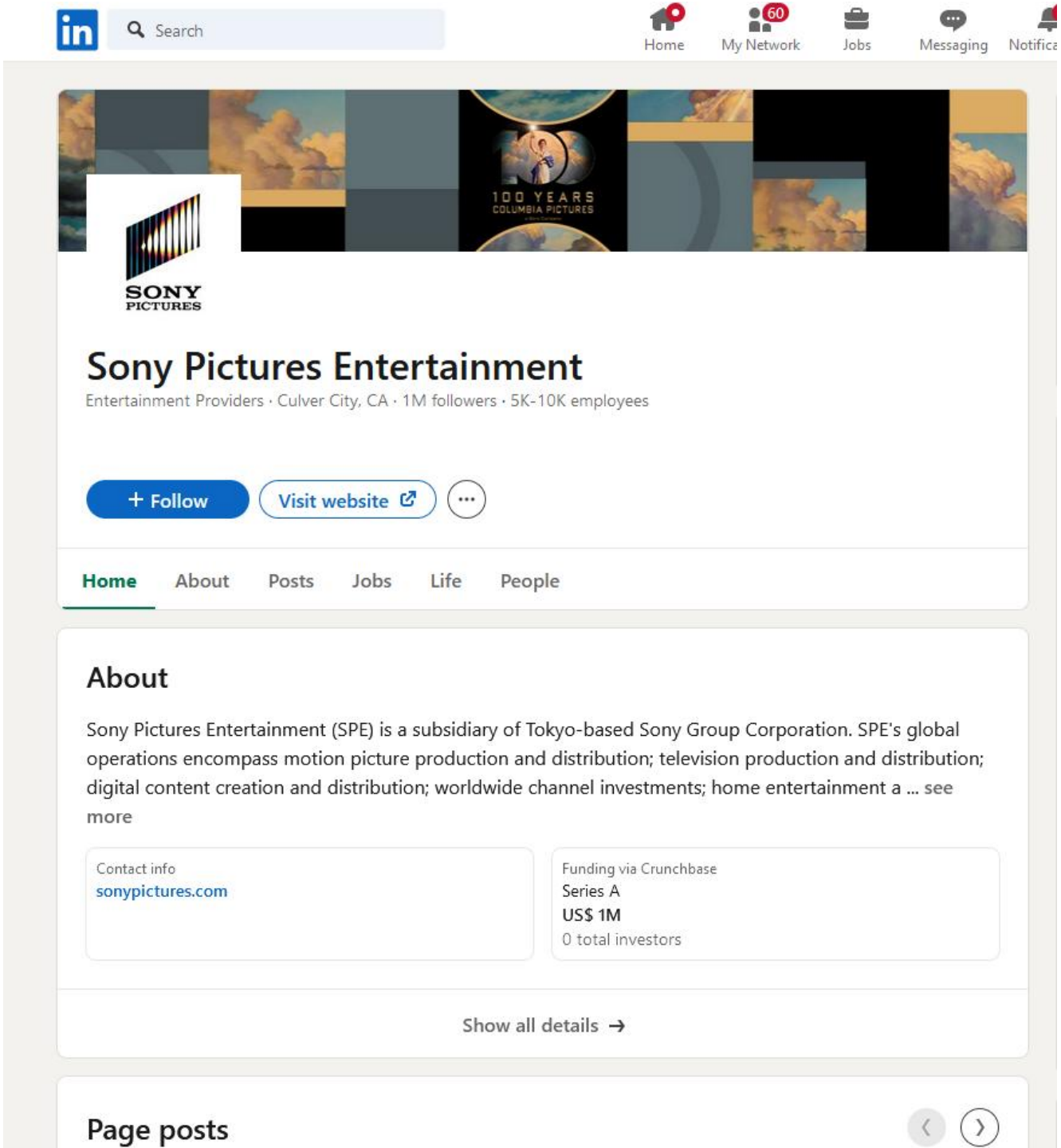
How Did It Start?

Cyber Kill Chain



1 - Recon

1 - Recon



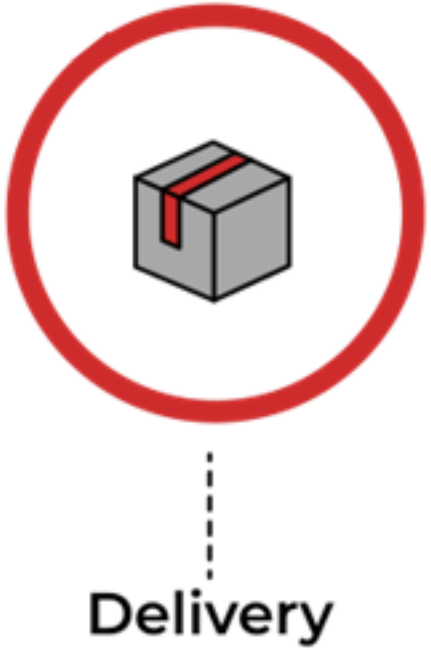
Recon

2 - Weaponization

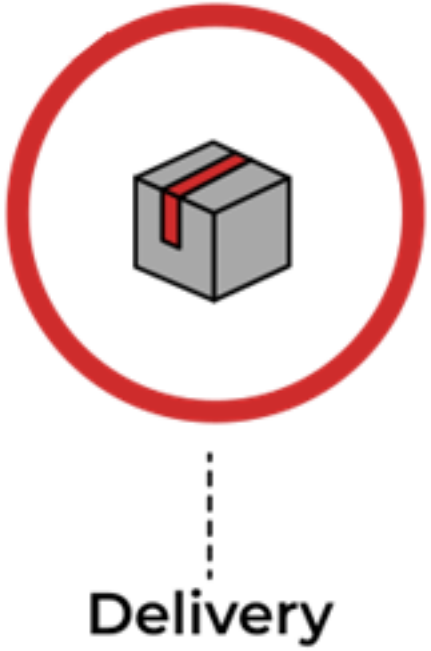
2 - Weaponization

- Destroyer Trojan Wiper
  - Improvement over Shamoon and DarkSeoul used in previous attacks
- EldoS Disk Driver
- Web Server
- Malware had hardcoded internal IP addresses to Sony Pictures and credentials for servers
- Custom Malware to avoid anti-virus

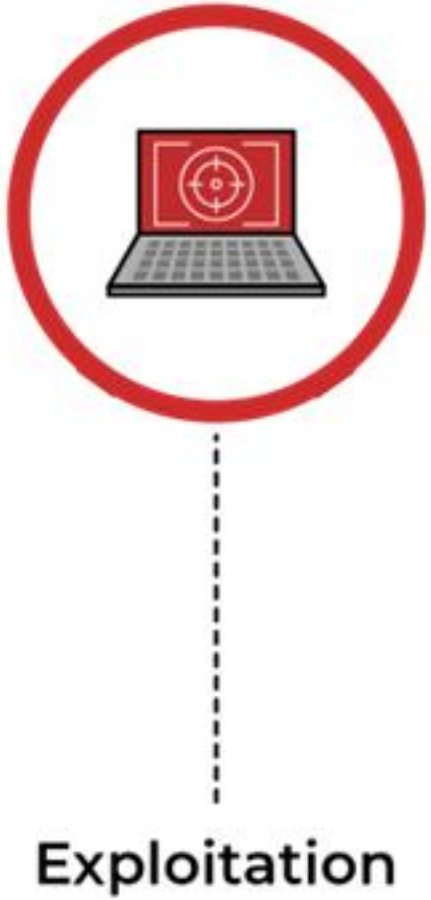
3 - Delivery



3 - Delivery



4 - Exploitation



4 - Exploitation

Dear Anthony Bouchard,

Apple requires email verification periodically. You may not be able to use your Apple ID or have access to certain Apple systems until you complete the email verification associated with your Apple ID.

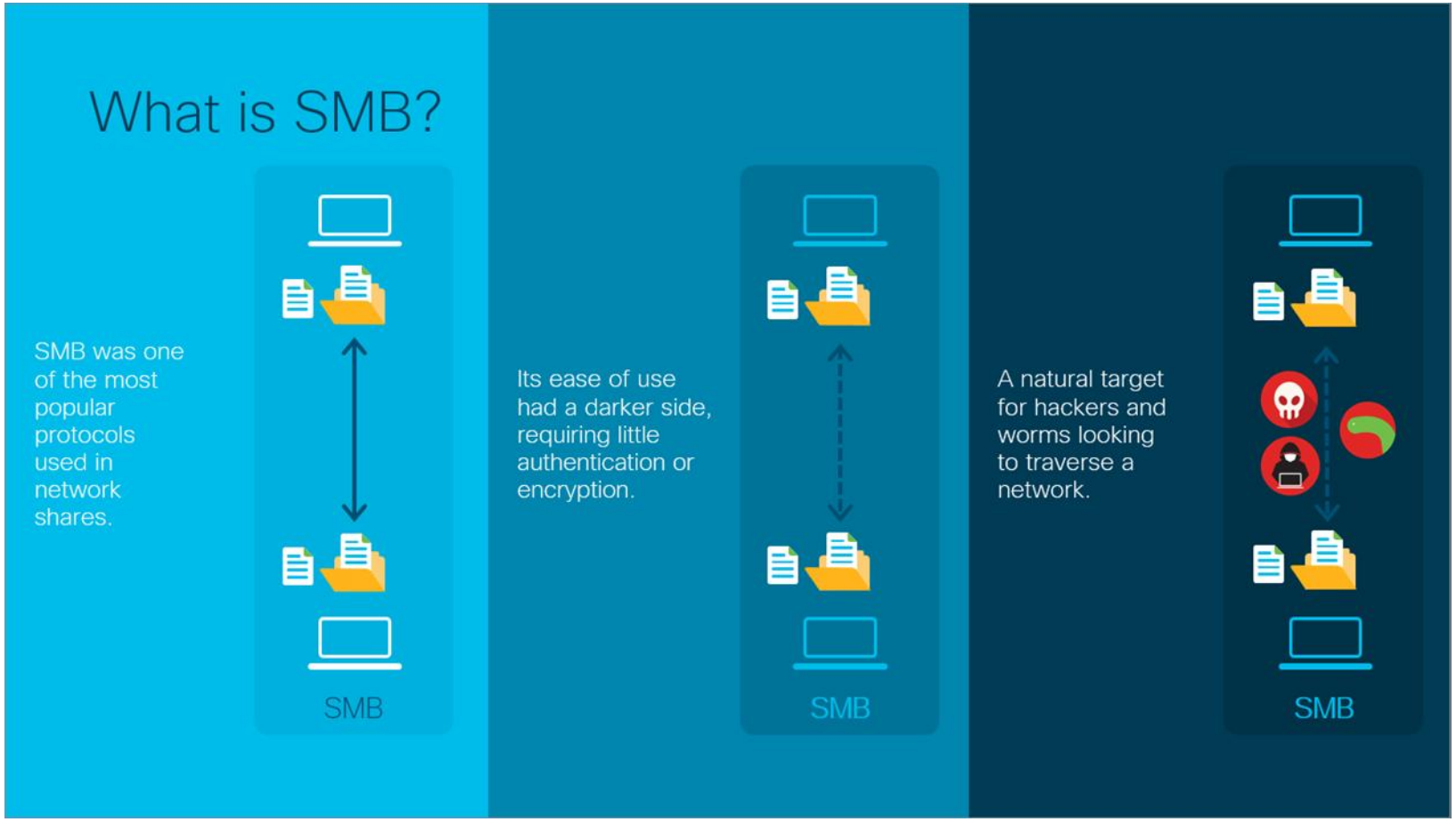
To verify this email address belongs to you, click the link below and then sign in using your Apple ID and password.

Verify now >

Apple Support

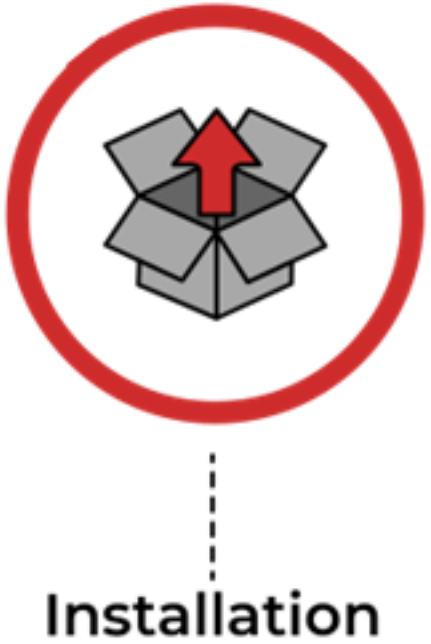
Exploitation

4 - Exploitation



Exploitation

5 - Installation

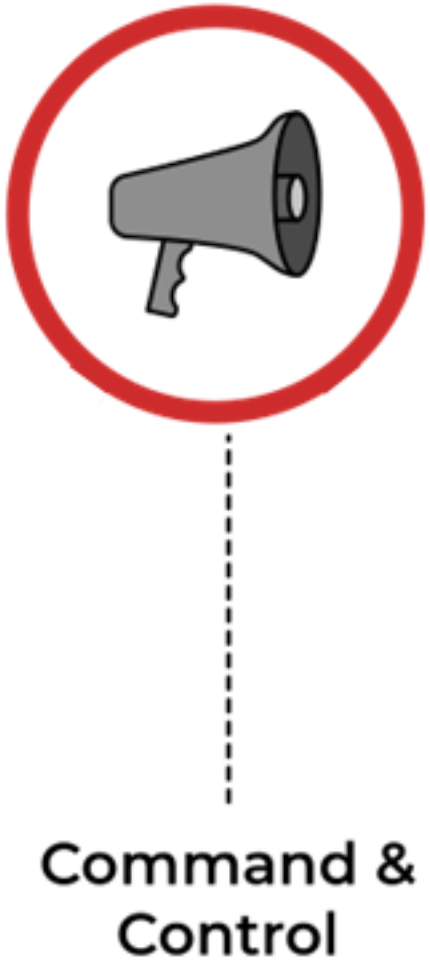


6 – Command and Control

Command &
Control

6 – Command and Control

- At least 3 C&C servers
  - Italy at former VPN endpoint
  - Polish business
  - University in Thailand

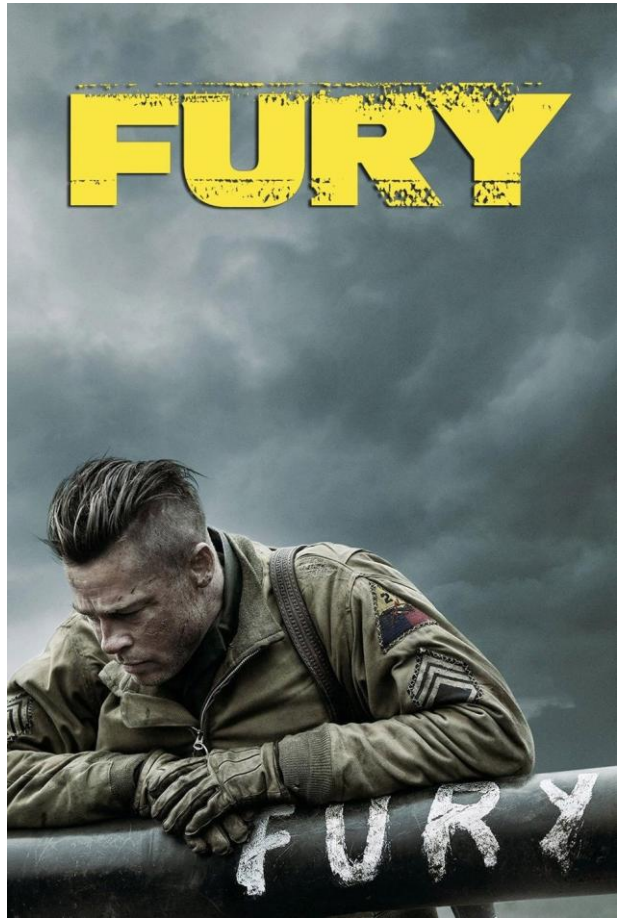


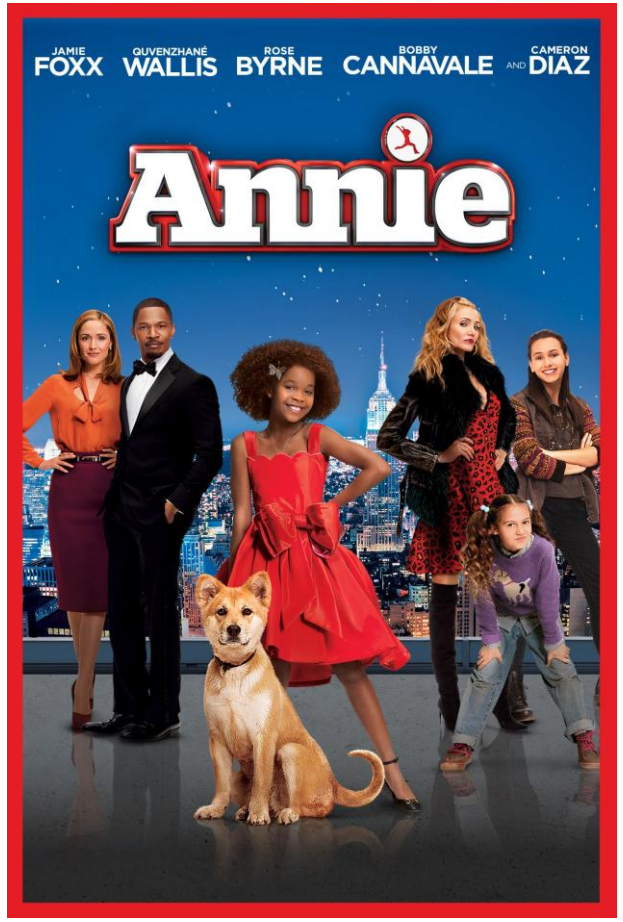
7 – Actions on Objectives

7 – Actions on Objectives

Actions on Objectives

7 – Actions on Objectives





7 – Actions on Objectives

Actions on Objectives

7 – Actions on Objectives

- > 100TB stolen data
- 5 Unreleased movies leaked
- Scripts
- Emails
- > 3,000 computers and 750 servers wiped
- 47,000 Social Security Numbers
- Salaries, addresses, and other personal information

What Happened Next?

Cybersecurity to Physical Security

Recovery?
Improvements?

The Aftermath

Guardians of Peace
WhoIs Team
Hidden Cobra
APT 37
APT38
Stardust Chollima

NewRomanic Cyber Army
Zinc
Nickel Academy
Kimsuky
BlueNoroff Group
AndAriel

- https://attack.mitre.org/groups/G0032/
- https://services.google.com/fh/files/misc/apt38-un-usual-suspects.pdf

WANTED BY THE FBI

PARK JIN HYOK

Conspiracy to Commit Wire Fraud and Bank Fraud; Conspiracy to Commit Computer-Related Fraud (Computer Intrusion)

DESCRIPTION

Aliases: Jin Hyok Park, Pak Jin Hek, Pak Kwang Jin	
Place of Birth: Democratic People's Republic of Korea (North Korea)	**Hair:** Black
Eyes: Brown	**Sex:** Male
Race: Asian	**Languages:** English, Korean, Mandarin Chinese

REMARKS

Park is a North Korean citizen last known to be in North Korea. Park has traveled to China in the past and has reported dates of birth in 1984 and 1981.

CAUTION

Park Jin Hyok is allegedly a state-sponsored North Korean computer programmer who is part of an alleged criminal conspiracy responsible for some of the costliest computer intrusions in history. These intrusions caused damage to computer systems of, and stole currency and virtual currency from, numerous victims.

WANTED BY THE FBI

JON CHANG HYOK

Conspiracy to Commit Wire Fraud and Bank Fraud; Conspiracy to Commit Computer-Related Fraud (Computer Intrusion)

DESCRIPTION

Aliases: Quan Jiang, Alex Jiang	
Place of Birth: Democratic People's Republic of Korea (North Korea)	**Hair:** Black
Eyes: Brown	**Sex:** Male
Race: Asian	**Languages:** English, Korean, Mandarin Chinese

REMARKS

Jon is a North Korean citizen last known to be in North Korea. Jon has traveled to China in the past and has reported a date of birth in 1989.

CAUTION

Jon Chang Hyok is allegedly a state-sponsored North Korean hacker who is part of an alleged criminal conspiracy responsible for some of the costliest computer intrusions in history. These intrusions caused damage to computer systems of, and stole currency and virtual currency from, numerous victims.

Jon was alleged to be a participant in a wide-ranging criminal conspiracy undertaken by a group of hackers of the North Korean government's Reconnaissance

WANTED BY THE FBI

KIM IL

Conspiracy to Commit Wire Fraud and Bank Fraud; Conspiracy to Commit Computer-Related Fraud (Computer Intrusion)

DESCRIPTION

Aliases: Julien Kim, Tony Walker	
Place of Birth: Democratic People's Republic of Korea (North Korea)	**Hair:** Black
Eyes: Brown	**Sex:** Male
Race: Asian	**Languages:** English, Korean, Mandarin Chinese

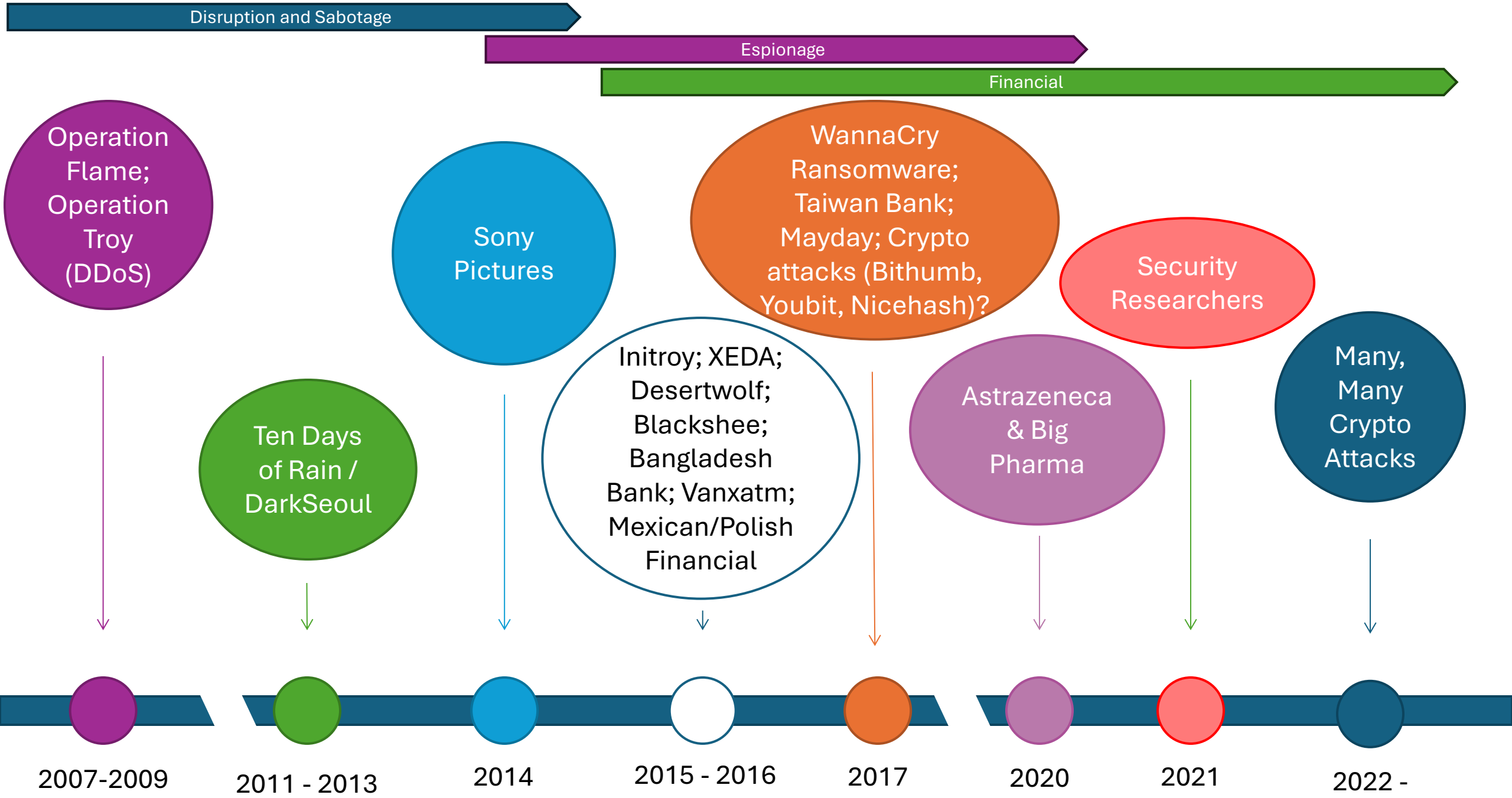
REMARKS

Kim is a North Korean citizen last known to be in North Korea. Kim has traveled to Singapore and Russia in the past and has reported a date of birth in 1994.

CAUTION

Kim Il is allegedly a state-sponsored North Korean hacker who is part of an alleged criminal conspiracy responsible for some of the costliest computer intrusions in history. These intrusions caused damage to computer systems of, and stole currency and virtual currency from, numerous victims.

Kim was alleged to be a participant in a wide-ranging criminal conspiracy undertaken by a group of hackers of the North Korean government's Reconnaissance General Bureau (RGB). The conspiracy comprised North Korean hacking groups that some private cybersecurity researchers have labeled the "Lazarus Group" and Advanced Persistent Threat 38 (APT38). For his part in the conspiracy, Kim is alleged to have been directly involved in the development and dissemination


Disruption and Sabotage
Espionage
Financial
Operation Flame; Operation Troy (DDoS)
Ten Days of Rain / DarkSeoul
Sony Pictures
Initroy; XEDA; Desertwolf; Blackshee; Bangladesh Bank; Vanxatm; Mexican/Polish Financial
WannaCry Ransomware; Taiwan Bank; Mayday; Crypto attacks (Bithumb, Youbit, Nicehash)?
Astrazeneca & Big Pharma
Security Researchers
Many, Many Crypto Attacks
2007-2009
2011 - 2013
2014
2015 - 2016
2017
2020
2021
2022 -

LAZARUS